

Презентация (Защита ПК и телефона)

Шифрование диска. Пароли. Фишинг. Вирусы. Мессенджеры

Шифрование диска: загрузочный сектор

Загрузочный сектор (MBR или EFI) можно зашифровать.

Современные средства Full Disk Encryption (BitLocker, VeraCrypt, LUKS) шифруют весь диск, включая системные области.

Загрузчик остаётся в незашифрованном виде (или отдельном разделе), но сам загрузочный сектор как часть диска шифруется.

Шифрование диска: какой алгоритм используется

Шифрование диска основано на симметричном шифровании.

Почему симметричное: - высокая скорость работы - алгоритмы: AES, Serpent, Twofish

Схема работы: 1. Генерация случайного симметричного ключа шифрования диска 2. Шифрование содержимого диска этим ключом 3. Шифрование самого ключа (асимметричным ключом или на основе пароля)

Хэширование используется только для проверки пароля, не для шифрования данных.

Программы для шифрования диска

BitLocker – встроенное средство Windows (Pro/Enterprise)

VeraCrypt – бесплатная кроссплатформенная программа (полное шифрование дисков и зашифрованные контейнеры)

Disk Utility – утилита macOS (зашифрованные образы дисков и разделы)

Не подходит: Wireshark (анализатор сетевого трафика)

Стойкие пароли

Требования к стойкому паролю: - длина от 10 символов - разные типы символов: заглавные и строчные буквы, цифры, специальные символы - отсутствие словарных слов, клавиатурных последовательностей (qwerty), личной информации

Пример стойкого пароля: UQr9@j4!S\$

Примеры слабых паролей: - qwerty12345 – клавиатурная последовательность - ILOVECATS – только буквы, словарное выражение - IDONTLOVECATS – только буквы, осмысленная фраза

Где безопасно хранить пароли

Безопасное место: менеджеры паролей (KeePass, Bitwarden, 1Password, LastPass)

Преимущества менеджеров паролей: - хранение паролей в зашифрованном виде - требуется мастер-пароль - синхронизация между устройствами

Небезопасные места: - заметки на рабочем столе или в телефоне - стикер на мониторе - кошелёк

Зачем нужна капча

CAPTCHA различает людей и ботов.

Что предотвращает капча: - автоматический перебор паролей (brute force) - создание множества аккаунтов ботами - накрутку голосований - спам в формах

Капча не заменяет пароли, не хранит пароли, не защищает куки.

Хэширование паролей

При регистрации сервер вычисляет хэш пароля (с солью) и сохраняет только хэш.

При входе хэш введённого пароля сравнивается с сохранённым.

Если база данных утечёт, злоумышленник получит только хэши, а не пароли в открытом виде.

Хэширование не предназначено для: - скрытия пароля при передаче (это задача TLS) - ускорения авторизации (наоборот, замедляет)

Соль при хэшировании паролей

Что делает соль: - защищает от радужных таблиц - делает разные хэши для одинаковых паролей у разных пользователей

Что не делает соль: - не увеличивает энтропию слабого пароля - не предотвращает атаку перебором (brute force) при украденной базе хэшей

Вывод: при доступе к базе хэшей с солями злоумышленник может перебирать пароли по одному для каждого пользователя.

Меры защиты от атаки перебором

Какие меры работают: - разные пароли на всех сайтах – сдерживание ущерба при взломе одного сайта - сложные (длинные) пароли – увеличение пространства поиска - капча – блокировка автоматизированного перебора

Спорная мера: - периодическая смена паролей – не защищает от перебора “здесь и сейчас”, может приводить к выбору слабых предсказуемых паролей

Фишинг: как распознать поддельную ссылку

Фишинговая ссылка ведёт на поддельный сайт на чужом домене.

Примеры фишинговых ссылок: - online.sberbank.wix.ru – Сбербанк использует sberbank.ru, а не wix.ru
- passport.yandex.ucoz.ru – Яндекс использует yandex.ru, а не ucoz.ru

Безопасные ссылки: - accounts.google.com.br – домен принадлежит Google - e.mail.ru – домен принадлежит Mail.ru

Фишинг: может ли письмо прийти от знакомого адреса

Да, может.

Способы подделки: - спуфинг (подделка обратного адреса) - взлом ящика знакомого человека

Поэтому фишинг особенно опасен – письмо может прийти с реального, знакомого адреса.

Email спуфинг

Спуфинг – это подмена адреса отправителя в имейлах.

Злоумышленник подделывает заголовки письма, чтобы оно выглядело как отправленное от имени банка, коллеги или друга.

Цель: обмануть получателя, заставить открыть вложение, перейти по ссылке или передать данные.

Спуфинг не является: - протоколом отправки имейлов (SMTP) - методом предотвращения фишинга - атакой перебором паролей

Вирус-троян

Троян – вредоносное ПО, которое маскируется под легитимную программу (игру, установщик, антивирус, кряк).

При запуске выполняет скрытые вредоносные действия.

Троян не обязан: - шифровать данные и требовать выкуп (это ransomware) - работать только на Windows - быть разработанным греками (шутка)

Signal: когда формируется ключ шифрования

Протокол Signal использует X3DH для асинхронного установления сессии.

Ключ шифрования формируется при генерации первого сообщения стороной-отправителем.

При установке приложения создаются только долговременные ключи, не сессионные.

При первом сообщении отправитель загружает предварительные ключи получателя и вычисляет общий ключ сессии.

Последующие сообщения используют уже сформированный ключ.

Сквозное шифрование (E2EE)

Суть сквозного шифрования: сообщение шифруется на устройстве отправителя и расшифровывается только на устройстве получателя.

Промежуточные узлы (серверы мессенджера, провайдеры, маршрутизаторы) видят только зашифрованные данные и не могут их прочитать.

E2EE не означает: - что сервер получает сообщения в открытом виде - что сервер перешифровывает сообщения - что сообщения передаются без участия сервера (сервер нужен для хранения и маршрутизации) “